

PROJECT UPDATE 5

Secure AI Role Separation, Frontend Expansion, and Database Migration

AI-Powered E-Commerce Platform with Intelligent Business Insights

SUMMARY - Update 5 advances the project from basic integration toward a safer, more complete e-commerce system. The frontend now covers the main shopping and AI workflows; the backend team reported a PostgreSQL migration; and the AI layer now enforces role-based data separation so public users cannot extract administrator-only information.

1. FRONTEND PROGRESS - SHAKIB

The latest frontend is a React 19 single-page application built with Vite 8, Tailwind CSS 4 and React Router. It now presents a consistent storefront design across the primary customer journeys.

Route coverage: home, login, registration, products, product details, categories, cart, checkout, order history/details, profile, customer AI, admin AI and fallback page.

API integration: product/category browsing is public, while cart, checkout and order requests attach JWT Bearer tokens from local storage.

AI interfaces: separate customer and administrator chat pages include loading states, message histories, quick-question buttons and role-specific error messages.

Interface quality: responsive grids, searchable products, consistent navigation, styled forms and clear empty/error states improve usability.

2. BACKEND AND POSTGRESQL - RAHAT

Rahat reported that the backend was migrated toward PostgreSQL and shared the expected Django database configuration using the PostgreSQL engine on localhost port 5432.

Purpose: replace the development-only SQLite database with a multi-user relational database that is more suitable for concurrent transactions and deployment.

Expected configuration: database name myproject, PostgreSQL user abumdashrafulrahat, host localhost and port 5432.

Verification status: the combined ZIP reviewed for this report still contains SQLite settings and no PostgreSQL driver entry; therefore the PostgreSQL branch must still be merged and tested in the integrated build.

3. INTEGRATION REVIEW

The frontend endpoint map matches the Django REST structure for accounts, store, cart, orders and both AI chatbots.

Remaining integration gaps include a client-only profile form, hard-coded API URLs, a permanently visible Admin AI navigation link and limited pagination/error handling.

4. AI SECURITY ENHANCEMENT - FARHAN

A Role-Based AI Context Firewall was implemented to prevent a public customer from manipulating the local LLM into exposing protected business data.

Prompt-injection filter: suspicious requests such as “ignore previous instructions,” “act as admin,” database dumps, passwords and exact stock requests are rejected before Ollama is called.

Data minimization: the customer model receives only public catalogue fields and an Available/Out of stock label, not exact inventory counts, users, orders or revenue.

Role enforcement: the admin chatbot requires a valid JWT and Django staff permission; authenticated non-admin users receive HTTP 403.

Store protection: public product responses are sanitized, anonymous modification attempts return HTTP 401, and inventory endpoints require authenticated support/admin access.

Repository evidence: commit 4e138de was pushed to the FarhanRafid branch with 156 insertions and 18 deletions across the chatbot and store security files.

5. VERIFICATION RESULTS

DJANGO CHECK

No issues detected

INJECTION TEST

Blocked before Ollama

PUBLIC DATA

Exact stock removed

ANONYMOUS WRITE

HTTP 401 blocked

CUSTOMER -> ADMIN

HTTP 403 blocked

6. OUTCOME AND NEXT ACTIONS

Update 5 produced a demonstrable security improvement: identical business questions now receive different data according to user role, and customer prompt manipulation cannot cross the backend authorization boundary.

Merge and verify the PostgreSQL configuration, install the required database driver, run migrations and retest all APIs.

Add role-aware navigation/route guards, connect profile persistence and move the API base URL into environment configuration.

Run one complete customer flow: register, login, browse, cart, checkout, order history and customer/admin chatbot comparison.

EVIDENCE REVIEWED: latest BestCommerce ZIP; React/Django source files; successful PowerShell API tests; Git commit 4e138de; team PostgreSQL configuration message dated 2 August 2026. The ZIP itself still shows SQLite, so PostgreSQL is recorded as reported/pending integrated verification.